STUDI KASUS ANALISIS
Manajemen Risiko pada Laboratorium Komputer

Nama : Aldi Wilang Kesuma
NIM : 105240008
Kelas : 5A
Mata Kuliah : Konsep Risiko dan Sistem Pengendalian Internal

---

1. Pendahuluan

1.1 Latar Belakang

Laboratorium komputer adalah fasilitas penting di perguruan tinggi yang dipakai untuk praktikum, penelitian, dan ujian berbasis komputer. Di dalamnya tersimpan banyak informasi, misalnya data praktikum, nilai, soal ujian, dan akun mahasiswa serta dosen. Informasi ini berjalan di atas perangkat keras, perangkat lunak, dan jaringan yang masing-masing memiliki kelemahan.

Apabila kelemahan tersebut dimanfaatkan oleh ancaman, misalnya virus, pencurian, kesalahan pengguna, atau gangguan listrik, maka keamanan informasi dapat terganggu. Karena itu laboratorium perlu menjalankan manajemen risiko, yaitu proses yang terencana untuk mengenali risiko, menilai seberapa besar bahayanya, lalu menentukan tindakan agar risiko tersebut tidak merugikan.

1.2 Rumusan Masalah dan Tujuan

Permasalahan yang dibahas adalah: bagaimana manajemen risiko dari proses mengidentifikasi, menganalisis, mengevaluasi, dan menangani risiko yang dapat mengganggu kerahasiaan, integritas, dan ketersediaan (CIA) informasi pada laboratorium komputer. Tujuannya adalah menjelaskan tiap tahap tersebut secara runtut beserta penerapannya pada kasus laboratorium komputer.

2. Landasan Teori

2.1 Konsep CIA

CIA adalah tiga tujuan utama keamanan informasi:

- **Kerahasiaan (Confidentiality):** informasi hanya dapat diakses oleh pihak yang berhak. Contoh: soal ujian tidak boleh dilihat mahasiswa sebelum ujian.
- **Integritas (Integrity):** informasi tetap akurat, utuh, dan tidak berubah tanpa izin. Contoh: nilai praktikum tidak boleh diubah oleh orang yang tidak berwenang.
- **Ketersediaan (Availability):** informasi dan sistem dapat digunakan saat dibutuhkan. Contoh: komputer dan jaringan harus siap dipakai saat jadwal praktikum atau ujian.

2.2 Manajemen Risiko

Risiko adalah kemungkinan terjadinya kejadian yang merugikan. Dalam keamanan informasi, risiko muncul ketika ada aset yang bernilai, ancaman yang dapat menyerang aset itu, dan kelemahan (vulnerability) yang memungkinkan serangan berhasil. Proses manajemen risiko mengacu pada ISO 31000 dan ISO/IEC 27005, dengan urutan tahap sebagai berikut:

1. **Identifikasi risiko:** mencari dan mencatat risiko yang mungkin terjadi.
2. **Analisis risiko:** menilai kemungkinan dan dampak setiap risiko.
3. **Evaluasi risiko:** membandingkan hasil analisis dengan kriteria untuk menentukan prioritas.
4. **Penanganan risiko:** memilih dan menjalankan tindakan untuk mengurangi risiko.
5. **Pemantauan dan review:** memastikan pengendalian berjalan dan menilai ulang secara berkala.

3. Gambaran Objek Studi Kasus

Objek yang dianalisis adalah sebuah laboratorium komputer perguruan tinggi dengan asumsi sebagai berikut: memiliki sekitar 30 sampai 40 komputer client dan satu komputer server; terhubung ke jaringan kampus (LAN dan Wi-Fi) serta internet; digunakan oleh mahasiswa, dosen, dan laboran untuk praktikum dan ujian; dikelola oleh laboran di bawah pengawasan kepala laboratorium.

Tabel 1. Aset Informasi Laboratorium Komputer

No	Aset	Contoh	Unsur CIA Utama
1	Data	Data praktikum, nilai, soal ujian, akun pengguna	Kerahasiaan, Integritas
2	Perangkat keras	Komputer client, server, switch, router, access point	Ketersediaan
3	Perangkat lunak	Sistem operasi, aplikasi praktikum, antivirus	Integritas, Ketersediaan
4	Fasilitas	Ruangan, listrik, pendingin ruangan	Ketersediaan

4. Identifikasi Risiko

Identifikasi risiko adalah tahap awal untuk menemukan apa saja yang dapat mengganggu CIA. Caranya dengan menelusuri setiap aset, lalu mencari ancaman yang mungkin menyerangnya dan kelemahan yang membuat ancaman itu berhasil. Sumber informasinya dapat berupa pengamatan langsung di lab, wawancara dengan laboran, catatan kejadian sebelumnya, dan daftar periksa (checklist) keamanan.

Hasil identifikasi pada laboratorium komputer disajikan pada Tabel 2. Kolom terakhir menunjukkan unsur CIA yang terganggu bila risiko terjadi.

Tabel 2. Hasil Identifikasi Risiko

Kode	Aset	Ancaman	Kelemahan	Unsur CIA Terganggu
R1	Ruangan lab dan perangkat	Orang tidak berwenang masuk; pencurian komputer atau komponen	Pintu sering tidak terkunci; tidak ada CCTV; tidak ada daftar hadir pengguna	Kerahasiaan, Ketersediaan
R2	Komputer client dan server	Malware atau ransomware yang masuk lewat flashdisk atau unduhan	Antivirus tidak diperbarui; port USB bebas digunakan	Integritas, Ketersediaan
R3	Akun pengguna	Password ditebak atau dicuri; akun orang lain dipakai	Password lemah; satu akun dipakai bergantian	Kerahasiaan
R4	Data mahasiswa dan soal ujian	Data disalin atau bocor ke pihak yang tidak berhak	Data tersimpan di komputer lokal tanpa enkripsi dan tanpa pembatasan akses	Kerahasiaan
R5	Data praktikum dan konfigurasi sistem	Data atau pengaturan diubah/dihapus tanpa izin	Hak akses terlalu luas; tidak ada catatan aktivitas (log)	Integritas
R6	Perangkat keras dan listrik	Perangkat rusak; listrik padam mendadak	Tidak ada UPS; perawatan tidak terjadwal	Ketersediaan
R7	Data praktikum dan nilai	Data hilang karena disk rusak, serangan, atau salah hapus	Tidak ada prosedur dan jadwal backup	Ketersediaan, Integritas

Kode	Aset	Ancaman	Kelemahan	Unsur CIA Terganggu
R8	Sistem operasi dan aplikasi	Celah keamanan dimanfaatkan penyerang	Software bajakan; update dan patch tertunda	Kerahasiaan, Integritas, Ketersediaan

5. Analisis Risiko

Analisis risiko bertujuan mengetahui seberapa besar tiap risiko. Penilaian dilakukan secara semi-kuantitatif, yaitu memberi angka pada dua hal: kemungkinan terjadi (L) dan dampak bila terjadi (D). Nilai risiko dihitung dengan rumus:

Nilai Risiko = Kemungkinan (L) × Dampak (D)

Tabel 3. Skala Penilaian

Skala	Kemungkinan (L)	Dampak (D)
1	Sangat jarang terjadi	Sangat kecil, hampir tidak mengganggu
2	Jarang terjadi	Kecil, gangguan ringan
3	Kadang-kadang terjadi	Sedang, praktikum terganggu sebagian
4	Sering terjadi	Besar, praktikum atau ujian terhenti
5	Hampir pasti terjadi	Sangat besar, data hilang atau bocor permanen

Tingkat risiko ditentukan dari nilainya: 1–5 = Rendah, 6–11 = Sedang, 12–16 = Tinggi, dan 17–25 = Sangat Tinggi. Hasil penilaian ditunjukkan pada Tabel 4.

Tabel 4. Hasil Analisis Risiko

Kode	Risiko	L	D	Nilai	Tingkat	Alasan Penilaian
R1	Akses fisik tidak sah / pencurian perangkat	3	4	12	Tinggi	Bisa terjadi saat lab tanpa pengawasan; perangkat dan data hilang
R2	Malware / ransomware	4	4	16	Tinggi	Flashdisk sering dipakai; sistem bisa lumpuh dan data rusak
R3	Akun dan password lemah	4	3	12	Tinggi	Kebiasaan umum pengguna; membuka akses data orang lain
R4	Kebocoran data / soal ujian	3	4	12	Tinggi	Data mudah disalin; merugikan mahasiswa dan institusi
R5	Perubahan data tanpa izin	3	3	9	Sedang	Perubahan sulit dilacak; data menjadi tidak valid
R6	Kerusakan perangkat / listrik padam	4	3	12	Tinggi	Gangguan listrik cukup sering; praktikum terhenti
R7	Kehilangan data (tanpa backup)	3	5	15	Tinggi	Data tidak dapat dipulihkan; dampak paling berat
R8	Software tidak berlisensi / tidak diperbarui	4	3	12	Tinggi	Update sering terabaikan; membuka celah serangan

6. Evaluasi Risiko

Evaluasi risiko adalah tahap membandingkan hasil analisis dengan kriteria penerimaan risiko untuk memutuskan risiko mana yang harus ditangani lebih dulu. Karena sumber daya laboratorium (dana, waktu, tenaga) terbatas, tidak semua risiko dapat ditangani sekaligus. Kriteria yang digunakan:

Tabel 5. Kriteria Penerimaan Risiko

Tingkat	Nilai	Keputusan
Rendah	1 – 5	Diterima, cukup dipantau
Sedang	6 – 11	Dapat diterima dengan pengendalian dasar dan pemantauan
Tinggi	12 – 16	Tidak dapat diterima, harus ditangani segera
Sangat Tinggi	17 – 25	Tidak dapat diterima, penanganan darurat

Berdasarkan kriteria tersebut, tujuh dari delapan risiko berada pada tingkat Tinggi dan hanya R5 yang Sedang. Urutan prioritas penanganan adalah sebagai berikut:

1. **R2 Malware/ransomware (16).** Kemungkinannya paling besar dan mengancam integritas sekaligus ketersediaan, sehingga menjadi prioritas pertama.
2. **R7 Kehilangan data (15).** Dampaknya paling berat karena data tidak dapat dipulihkan jika tidak ada backup.
3. **R1, R3, R4, R6, dan R8 (masing-masing 12).** Semuanya Tinggi dan saling berkaitan, misalnya akun lemah (R3) memudahkan kebocoran data (R4), dan software tidak diperbarui (R8) memperbesar peluang malware (R2).
4. **R5 Perubahan data tanpa izin (9).** Tingkat Sedang, ditangani setelah risiko di atas.

Bila dikelompokkan menurut unsur CIA, risiko kerahasiaan paling banyak berkaitan dengan akses (R1, R3, R4), risiko integritas berkaitan dengan keaslian data dan sistem (R2, R5, R8), dan risiko ketersediaan berkaitan dengan keberlangsungan layanan (R1, R6, R7).

7. Penanganan Risiko

Penanganan risiko adalah tahap memilih dan menjalankan tindakan untuk menurunkan risiko ke tingkat yang dapat diterima. Pilihan strateginya ada empat:

- **Mitigasi:** mengurangi kemungkinan atau dampak risiko, misalnya memasang antivirus.
- **Transfer:** memindahkan sebagian risiko kepada pihak lain, misalnya asuransi atau garansi perangkat.
- **Avoidance:** menghindari sumber risiko, misalnya tidak memakai software bajakan.
- **Acceptance:** menerima risiko yang kecil dan memantaunya saja.

Pengendalian yang dipilih dikelompokkan menjadi tiga jenis. Pengendalian pencegahan mencegah kejadian sebelum terjadi, pengendalian detektif mendeteksi kejadian yang sedang atau sudah terjadi, dan pengendalian korektif memulihkan keadaan setelah kejadian. Rencana penanganan untuk setiap risiko ditunjukkan pada Tabel 6.

Tabel 6. Rencana Penanganan Risiko

Kode	Strategi	Pengendalian yang Diusulkan	Jenis Pengendalian	Penanggung Jawab
R1	Mitigasi	Kunci pintu dan lemari perangkat, pasang CCTV, wajibkan pengisian daftar hadir, batasi jam akses.	Pencegahan dan Detektif	Kepala Lab, Laboran

Kode	Strategi	Pengendalian yang Diusulkan	Jenis Pengendalian	Penanggung Jawab
R2	Mitigasi	Antivirus berlisensi dengan update otomatis, batasi flashdisk, pasang software restore agar komputer kembali bersih setelah restart.	Pencegahan dan Korektif	Laboran
R3	Mitigasi	Akun individu untuk setiap pengguna, kebijakan password (minimal 8 karakter kombinasi), logout otomatis.	Pencegahan	Laboran, Unit TI
R4	Mitigasi	Hak akses berbasis peran, soal ujian disimpan di server terpisah, data lokal dihapus setelah praktikum, enkripsi data sensitif.	Pencegahan	Kepala Lab
R5	Mitigasi	Aktifkan log aktivitas, terapkan hak akses minimal (least privilege), periksa log secara berkala.	Detektif	Laboran
R6	Mitigasi dan Transfer	Pasang UPS dan stabilizer, perawatan terjadwal, siapkan unit cadangan, manfaatkan garansi atau asuransi perangkat.	Pencegahan dan Korektif	Kepala Lab, Bagian Aset
R7	Mitigasi	Backup rutin dengan aturan 3-2-1 (3 salinan, 2 jenis media, 1 di luar lokasi) dan uji pemulihan secara berkala.	Korektif	Laboran
R8	Mitigasi dan Avoidance	Gunakan software berlisensi atau open source, hindari software bajakan, jadwalkan update dan patch keamanan.	Pencegahan	Laboran

7.1 Kaitan Pengendalian dengan CIA

- **Kerahasiaan:** akun individu, kebijakan password, hak akses berbasis peran, enkripsi, serta kontrol akses fisik seperti kunci dan CCTV.
- **Integritas:** antivirus dan software restore, log aktivitas, update dan patch, serta pembatasan perubahan konfigurasi.
- **Ketersediaan:** backup rutin, UPS, perawatan berkala, dan unit perangkat cadangan.

7.2 Risiko Residual

Setelah pengendalian diterapkan, risiko tidak hilang sepenuhnya. Risiko yang tersisa disebut risiko residual. Misalnya, malware varian baru tetap dapat lolos meskipun antivirus aktif. Tabel 7 memperkirakan nilai risiko setelah pengendalian dijalankan, yang diharapkan turun ke tingkat Sedang atau Rendah sehingga dapat diterima.

Tabel 7. Perkiraan Risiko Setelah Pengendalian

Kode	Nilai Awal	Perkiraan Nilai Residual	Tingkat Residual
R1	12 (Tinggi)	6	Sedang
R2	16 (Tinggi)	8	Sedang
R3	12 (Tinggi)	6	Sedang
R4	12 (Tinggi)	6	Sedang
R5	9 (Sedang)	4	Rendah
R6	12 (Tinggi)	6	Sedang
R7	15 (Tinggi)	5	Rendah

Kode	Nilai Awal	Perkiraan Nilai Residual	Tingkat Residual
R8	12 (Tinggi)	6	Sedang

8. Pemantauan dan Review

Manajemen risiko bukan kegiatan sekali selesai karena ancaman dan teknologi terus berubah. Agar pengendalian tetap efektif, laboratorium perlu melakukan hal berikut:

- Menilai ulang risiko minimal satu kali setiap semester atau setelah ada perubahan besar, misalnya penggantian komputer atau sistem ujian baru.
- Melakukan audit internal untuk memeriksa kepatuhan terhadap SOP laboratorium.
- Mencatat setiap insiden (virus, kehilangan, gangguan listrik) dan mengevaluasi penyebabnya.
- Mensosialisasikan tata tertib dan kesadaran keamanan informasi kepada mahasiswa, dosen, dan laboran.

9. Kesimpulan

Manajemen risiko pada laboratorium komputer dijalankan melalui empat tahap yang berurutan. Identifikasi menemukan delapan risiko yang mengancam kerahasiaan, integritas, dan ketersediaan informasi. Analisis memberi nilai pada tiap risiko dengan mengalikan kemungkinan dan dampak. Evaluasi menetapkan prioritas, dengan malware/ransomware (nilai 16) dan kehilangan data akibat tidak ada backup (nilai 15) sebagai risiko terpenting. Penanganan dilakukan melalui pengendalian fisik, teknis, dan administratif yang diharapkan menurunkan risiko ke tingkat yang dapat diterima.

Dengan menjalankan proses ini secara konsisten dan memantaunya secara berkala, pengelola laboratorium dapat menentukan prioritas dengan tepat, menggunakan sumber daya secara efisien, dan menjaga keamanan informasi di laboratorium komputer.

Daftar Pustaka

ISO 31000:2018. Risk Management: Guidelines. International Organization for Standardization.

ISO/IEC 27001:2022. Information Security Management Systems: Requirements. International Organization for Standardization.

ISO/IEC 27005:2022. Guidance on Managing Information Security Risks. International Organization for Standardization.

NIST SP 800-30 Rev. 1. Guide for Conducting Risk Assessments. National Institute of Standards and Technology.

Materi kuliah Konsep Risiko dan Sistem Pengendalian Internal.